LLMs in Cyber Defense

Aaron Kaplan

Disclaimer

Does not speak nor represent customers… nor will mention them publicly without permissions

Whoami?

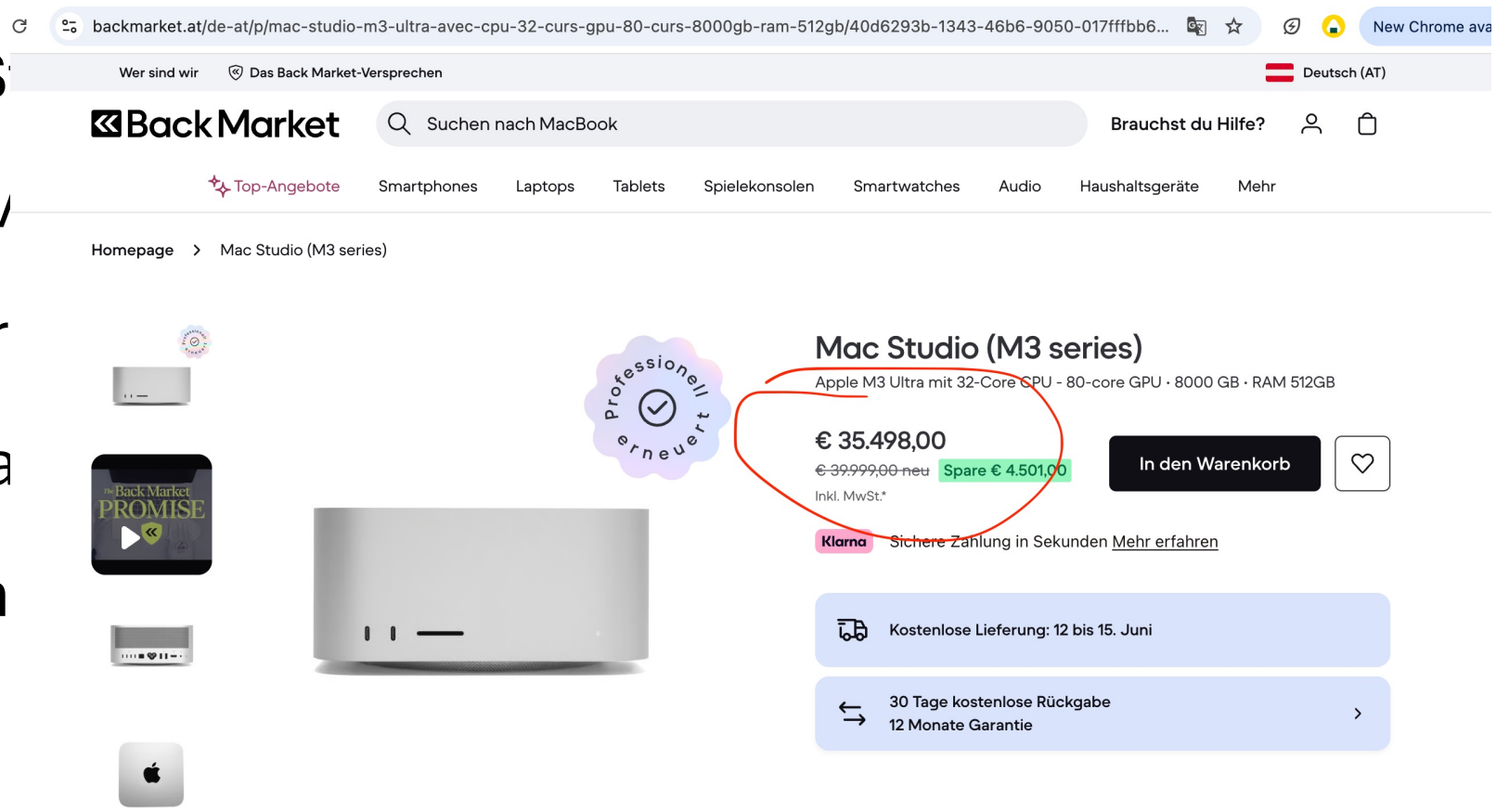
- Studied CS, pure maths @Vienna TU/Uni Wien
- Co-founder of Funkfeuer.at – DIY wireless mesh network
- Self employed many years
- 2008 started as employee #4 at CERT.at / nic.at GmbH
- 2020 self employed again – working for a large EUIBA – context IT Security team (50+ people)
- Built the AI Lab there

What I think about digital sovereignty

- Funkfeuer story
- “Housing project”
- Nic.at – domain zones for .at
- Kill-switch discussions
- At EUIBA – what about digital dependencies there?
- AI – who controls AI controls the world?
- But also inside the EU – digital sovereignty == “can I do it myself? / can I easily switch? Cost of switching?” – example tax advisor.

AI Lab @ work

- Idea: 4 Mac S
- Run large/adv
- 3 “stable” ser
- We can “airga
- “Lab”: that m
- 3 Stable, one



AI Lab @ work

- Running:
  - deepSeek-V4-*
  - GLM-5.3
  - Qwen3.8:27b, etc etc… (the “smaller” ones)
- Coming:
  - Newer models
  - Full mesh with Thunderbolt 5 (Exo). ETA next week ;-)

Okay, so… what can I do with that in “Cyber”?

Two main categories for “AI and Cyber”:

- AI 4 Cyber: what can we use it for in Cyber Security?
- Cyber 4 AI: What can IT Security help when it comes to securing AI?
- Not talking about: Regular AI-based productivity boosts (RAG on knowledge base, coding agents, etc.)

AI 4 Cyber

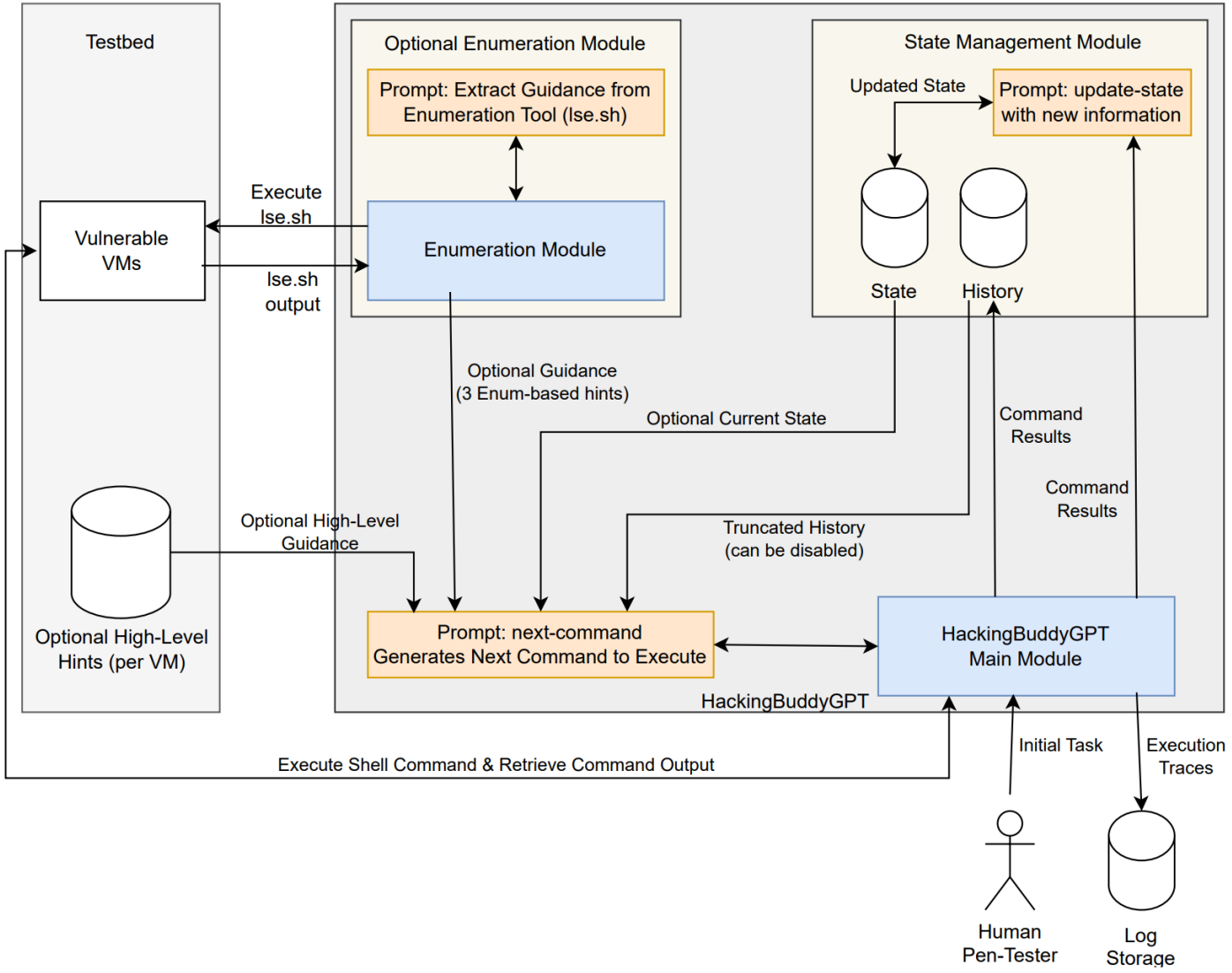
- All tasks related to **NLP**:
  - Analyzing disassbly code (IDA Pro -> Gepetto) https://github.com/aaronkaplan/gepetto
  - Situational awareness (CTI report in -> “what happened?”, “are we affected?”, “extract IoCs”, …) https://github.com/ctitools/
  - Datasets: https://orkl.eu/ (15k CTI reports)
  - Unstructured logs analysis (sysdiagnose): https://github.com/EC-DIGIT-CSIRC/sysdiagnose
  - Phishing detection
  - NER (tagging, etc.)
  - CTI report to YARA/signature detection, CTI 2 STIX, …
  - ….
- Vulnerability discovery:
  - Vuln assessment / scoring: given description, what’s the vuln? How serious is it?
  - Blackbox / on code
  - Or on source code, … **Mythos** (yes, we have a similar / slightly weaker system internally with local LLMs)

AI 4 Cyber (2)

- Classifiers:
  - Topic classifiers: f.ex. For MISP: https://github.com/AIPITCH/topic-classifier
  - Disinfo classifier?
  - Is_malware? (note: even works with CNNs)
  - Is_PUA?
  - Etc.
- And ofc, agentic systems:
  - Log analysis (FIRST.org CTF example)
  - Wintermute/pentest buddy: https://arxiv.org/abs/2310.11409

LLMs as hackers

- HackingBuddyGPT - https://arxiv.org/pdf/310.11409



General impression

- Everything that is ammendable to RL is working very well or will work very well

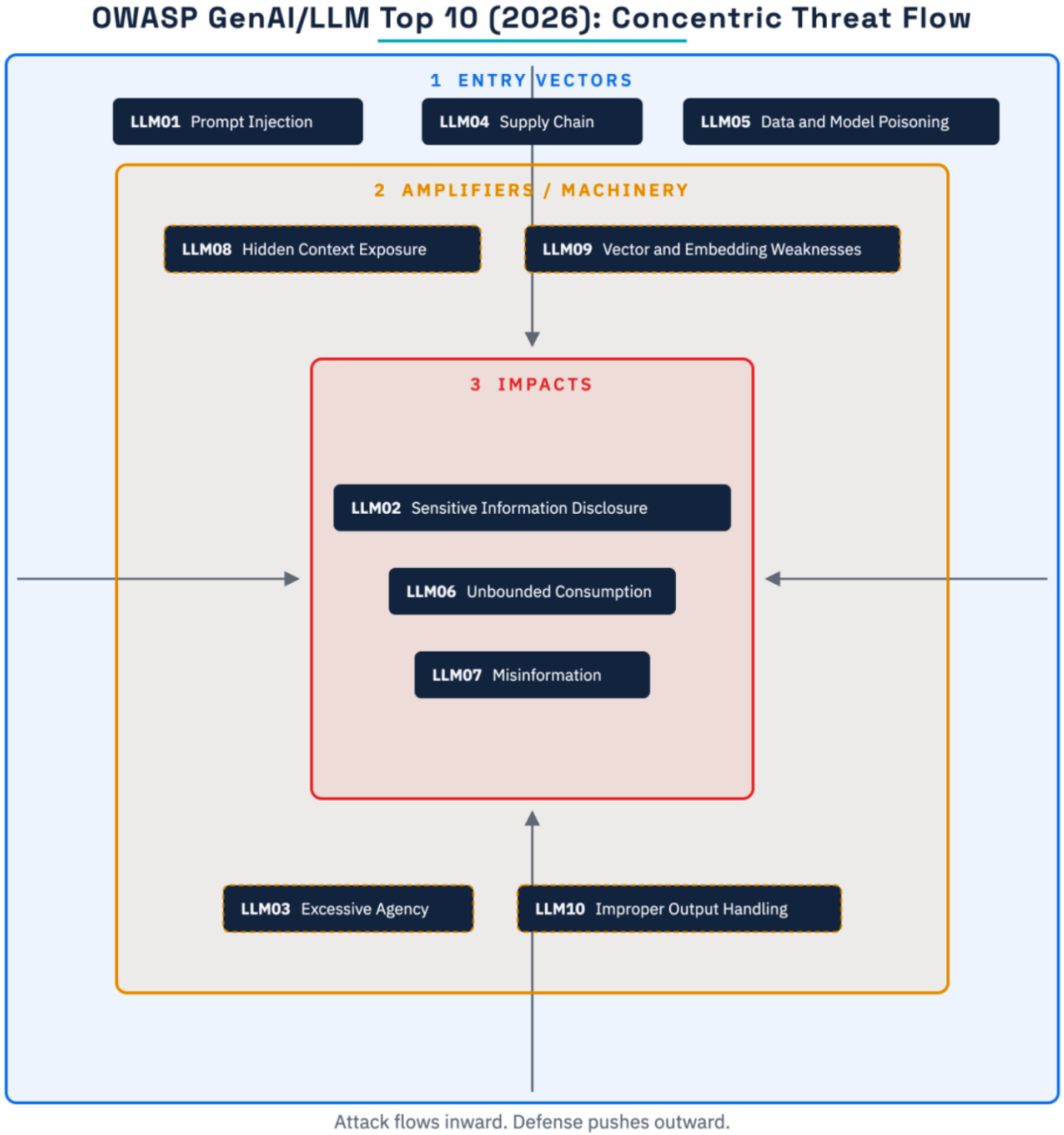
Cyber 4 AI

- Similar to SQLi:
  - Prompt injections
  - “story telling” (grandmother)
- → development of LLM pentesting tools:
  - Garak (now part of Nvidia): https://github.com/leondz/garak
    “*garak checks if an LLM can be made to fail in a way we don't want. garak probes for hallucination, data leakage, prompt injection, misinformation, toxicity generation, jailbreaks, and many other weaknesses. If you know nmap or msf / Metasploit Framework, garak does somewhat similar things to them, but for LLMs*.”

Cyber 4 AI (2)

- Impossibility theorem? Impossible to prevent prompt injections?
- If true, this has dire consequences on using LLM models in agentic (unsupervised?) loops
- We will have to re-define risk assessments
- OWASP Top-10 AI and OWASP Top-10 Agentic AI https://owasp.org/www-project-top-10-for-large-language-model-applications/ https://genai.owasp.org/resource/owasp-genai-llm-top-10-2026/
- Also look at: https://genai.owasp.org/resource/state-of-agentic-ai-security-and-governance/

OWASP Top 10 Gen AI overview



Example: ollama vs. GPT-5.4

- Used codex (gpt-5.4) to automate benchmarks on my RTX4090 setup.
- Codex (gpt-5.4) kicked out all ollama models :-)

  -- >OWASP top 10 overreliance on LLM s

- Nice reading: “LLMs can’t jump”, https://www.tomzahavy.com/projects/llms-cant-jump

Summary + pointers

There is too much for a short talk

FR night AI hackathons

FIRST AI SIG

Need some support with ctitools

Contact: aaron@-atsign-remove-this-part-lo-res.org